GUÍA PRÁCTICA · OCTUBRE DE 2026

GOBERNANZA DE DATOS E INTELIGENCIA ARTIFICIAL

De ISO/IEC 42001 a los agentes autónomos: datos confiables, permisos, evidencia y control de acciones



Idea central

La gobernanza de IA debe controlar tanto la información que utiliza un sistema como las decisiones y acciones que puede ejecutar. Esto resulta crítico cuando un LLM consulta bases de datos, utiliza herramientas o modifica sistemas empresariales.

Para equipos de datos, seguridad, TI, negocio, cumplimiento y legal

1. La cadena de gobernanza de IA

La gobernanza debe acompañar todo el ciclo de vida de la información, desde su origen hasta las decisiones y acciones realizadas por un sistema. Los controles de acceso, contexto y seguridad deben operar durante todo el proceso.



Principio fundamental: ningún componente posterior debe poder eludir las restricciones establecidas en las etapas anteriores. Un modelo puede proponer una acción, pero no debe poder ampliar por sí mismo sus privilegios.

Controles mínimos por etapa

Etapa	Pregunta de control	Evidencia mínima
Datos y fuentes	¿Quién es el propietario y cuál es la finalidad permitida?	Catálogo, clasificación, calidad y responsable.
Identidad y acceso	¿Qué identidad consulta el sistema y qué puede hacer?	Identidad técnica, permisos efectivos y caducidad.
Linaje y contexto	¿De dónde viene el dato y cuándo se actualizó?	Fuente, versión, transformaciones y fecha.
Modelo LLM	¿La respuesta está sustentada y dentro de la política?	Prompt/contexto relevante, versión y resultado.
Agente y ejecución	¿La acción está permitida y requiere aprobación?	Herramienta, parámetros, política aplicada y aprobación.
Evidencia y auditoría	¿Puede reconstruirse qué ocurrió y por qué?	Trazas correlacionadas, resultado y responsable.

2. Fallos reales: qué enseñan sobre gobernanza

Los casos siguientes ilustran distintos puntos de fallo. La categoría de gobernanza es una interpretación analítica para esta guía, no necesariamente la clasificación oficial del incidente.

Caso y dimensión	Qué ocurrió	Controles que lo habrían reducido
Air Canada (2024) **Contexto y veracidad**	Un chatbot proporcionó información incorrecta sobre la posibilidad de solicitar retroactivamente una tarifa por duelo. Un tribunal civil de Columbia Británica responsabilizó a la aerolínea por la información ofrecida por su chatbot.	Recuperar políticas oficiales; priorizar fuentes aprobadas; validar afirmaciones; escalar cuando no haya evidencia suficiente.
Samsung (2023) **Acceso y clasificación**	Empleados introdujeron código fuente e información interna en herramientas externas de IA generativa. Samsung restringió el uso tras detectar el problema.	Clasificación de datos; herramientas aprobadas; prevención de pérdida de datos (DLP); restricciones de carga y retención.
Zillow Offers (2021) **Modelo y riesgo**	Zillow cerró su negocio de compra de viviendas tras pérdidas relacionadas con precios de compra superiores a las estimaciones de venta y limitaciones operativas.	Validación fuera de muestra; escenarios; seguimiento del error; detección de cambios; límites de exposición financiera. No atribuir todo el desenlace a un único algoritmo.
Replit / SaaStr (2025) **Permisos y ejecución**	El incidente reportado sobre un agente de programación que actuó en un entorno de producción ilustra el riesgo de conceder a un agente permisos amplios y acceso a datos críticos sin barreras robustas.	Separar desarrollo y producción; mínimo privilegio; entornos de prueba; copias recuperables; aprobaciones humanas para acciones destructivas.

Lectura transversal

Los fallos no se resuelven únicamente mejorando el modelo. Se necesitan fuentes confiables, permisos técnicamente exigibles, límites de ejecución, supervisión proporcional al riesgo y evidencia que permita investigar el incidente.

3. Permisos por sistema: mínimo privilegio

Una identidad de agente no debería heredar automáticamente todos los permisos del usuario que la creó. Los permisos se asignan por tarea, sistema, recurso, operación y duración; las acciones de alto impacto requieren controles adicionales.

Sistema	Acceso inicial recomendado	Acciones de riesgo alto	Control adicional
CRM	Lectura de clientes asignados; campos necesarios.	Exportación masiva, cambios de propietario, borrado.	Filtro por registro/campo; límite de volumen; auditoría.
ERP	Lectura de órdenes y estados; datos financieros minimizados.	Crear pagos, modificar cuentas bancarias, aprobar compras.	Doble aprobación; segregación de funciones; límites monetarios.
Data Lake	Acceso a conjuntos autorizados y vistas curadas.	Leer datos sensibles en bruto o exportar grandes volúmenes.	Etiquetas de sensibilidad; masking; consultas registradas.
Correo	Lectura de carpetas autorizadas o borradores.	Enviar externamente, responder a todos, borrar mensajes.	Confirmación previa; listas de destinatarios; registro de envío.
Base de datos de producción	Lectura mediante vistas o réplica.	UPDATE/DELETE, DDL, cambios de esquema.	Sin escritura por defecto; transacciones; aprobación y rollback.
APIs financieras	Entorno sandbox; claves con alcance limitado.	Transferencias, reembolsos, cambios de beneficiario.	Vault de secretos; idempotencia; límites y aprobación humana.

Patrón recomendado: observar → proponer → validar → aprobar → ejecutar → verificar



Para acciones irreversibles o de impacto material, no basta con que el modelo “esté seguro”: la autorización debe validarse fuera del modelo, en el servicio que ejecuta la acción.

4. Cadena de evidencia y auditoría

La trazabilidad debe permitir reconstruir la decisión sin depender de la memoria conversacional del agente. Use identificadores de correlación para enlazar cada paso, con protección de datos personales y secretos.



Registro mínimo recomendado

Elemento	Campos útiles	Por qué importa
Fuente	ID de fuente, versión, fecha, propietario, hash cuando proceda.	Permite saber qué información se utilizó.
Acceso	Identidad del usuario/agente, permisos efectivos, recurso, política.	Demuestra que el acceso estaba autorizado.
Contexto	Documentos recuperados, transformaciones, filtros y vigencia.	Ayuda a explicar respuestas erróneas o incompletas.
Decisión	Modelo/versión, herramientas consideradas, salida relevante.	Permite investigar el comportamiento del sistema.
Aprobación	Persona o regla autorizante, momento, alcance y límites.	Acredita el control previo a la acción.
Ejecución	Herramienta, parámetros, código de estado, resultado y reversión.	Distingue entre una propuesta y una acción realizada.

Privacidad: registrar no significa almacenar indiscriminadamente prompts completos, credenciales o datos sensibles. Defina minimización, acceso a logs, retención, redacción y eliminación conforme a la finalidad y al RGPD.

5. Preguntas de gobernanza que debe poder responder

Pregunta	Control esperado	Señal de alerta
¿Qué datos puede usar la IA?	Catálogo, clasificación, finalidad y políticas de uso.	El agente puede consultar cualquier carpeta o tabla.
¿Quién responde por el resultado?	Propietario del proceso y responsable del sistema claramente asignados.	“La IA lo hizo” se usa como explicación final.
¿Qué puede ejecutar sin aprobación?	Matriz de acciones, umbrales y reglas técnicas fuera del LLM.	Un prompt puede desencadenar un pago o borrado.
¿Cómo se demuestra lo ocurrido?	Logs correlacionados y evidencia de permisos, contexto y resultado.	Solo existe el historial visible del chat.
¿Cómo se revoca el acceso?	Credenciales revocables, caducidad, rotación y kill switch.	Tokens persistentes o compartidos entre agentes.
¿Cómo se prueba antes de producción?	Evaluaciones, casos adversariales, pruebas de regresión y rollback.	Se despliega solo porque la demo funcionó.

Señales de madurez

Una organización madura puede identificar los sistemas de IA en uso, justificar el acceso a cada fuente, limitar acciones por riesgo, reconstruir incidentes y demostrar que las políticas se aplican técnicamente, no solo en documentos.

6. Marcos y regulación: cómo encajan

Estos marcos se complementan: unos orientan el sistema de gestión, otros estructuran el riesgo, otros organizan los datos y la regulación impone obligaciones aplicables según el caso.

Marco	Aporta	Uso práctico
ISO/IEC 42001:2023	Sistema de gestión de IA (AIMS), política, roles, evaluación y mejora continua.	Gobernar el ciclo de vida, asignar responsabilidades y mantener evidencia de gestión.
NIST AI RMF 1.0 (2023)	Funciones Govern, Map, Measure y Manage.	Identificar contexto, medir riesgos y seleccionar tratamientos.
Reglamento europeo de IA (AI Act)	Obligaciones por categoría de riesgo, rol y caso de uso; aplicación gradual.	Determinar alcance, clasificación, obligaciones y calendario aplicable.
DAMA-DMBOK	Prácticas de gestión de datos: calidad, metadatos, arquitectura, seguridad y gobierno.	Conectar la gobernanza de IA con los procesos de datos existentes.
RGPD	Principios y obligaciones sobre datos personales, derechos, seguridad y responsabilidad.	Base jurídica, minimización, transparencia, retención y evaluación cuando corresponda.

Importante

La certificación ISO/IEC 42001 no equivale por sí sola a cumplimiento automático del AI Act o del RGPD. La aplicabilidad depende de la organización, el sistema, el propósito, el papel desempeñado y las fechas de aplicación. Verifique la versión normativa vigente y obtenga asesoramiento especializado cuando el riesgo lo justifique.

7. Matriz RACI de responsabilidades

R = Responsible (ejecuta); A = Accountable (responde y aprueba); C = Consulted (consultado); I = Informed (informado). Debe adaptarse al tamaño y estructura de cada organización; cada actividad debería tener una única A claramente identificada.

Actividad	Datos	Seguridad	TI / Plataforma	Negocio	Legal / Cumpl.
Clasificar fuentes y definir calidad	A/R	C	C	C	I
Definir identidad y permisos	C	A	R	C	I
Aprobar caso de uso y riesgo	C	C	C	A/R	C
Diseñar logs y retención	C	A	R	C	C
Validar modelo y pruebas	C	C	R	A	C
Autorizar acciones de alto impacto	I	C	R	A	C
Gestionar incidentes y notificación	C	R	R	A	C
Revisión periódica y mejora	C	C	R	A	C

Consejo de implantación

Formalice la RACI junto con un inventario de sistemas, propietarios de datos, responsables de proceso y responsables de riesgo. Evite que el proveedor del modelo sea el único responsable de decisiones de negocio o de permisos empresariales.

8. Despliegue por etapas y niveles de riesgo

Fase	Qué hacer	Resultado esperado
1. Inventario	Registrar modelos, agentes, herramientas, fuentes, usuarios, propietarios y finalidad.	Mapa de sistemas de IA y flujos de datos.
2. Política mínima	Definir clasificación, acceso, retención, revisión humana, incidentes y usos prohibidos.	Reglas simples, entendibles y aprobadas.
3. Controles técnicos	Aplicar mínimo privilegio, gateway de herramientas, separación de entornos, validación de parámetros y aprobación.	Las políticas se hacen cumplir por arquitectura.
4. Monitorización	Medir fallos, accesos, acciones, latencia, deriva, excepciones y resultados; probar recuperación.	Evidencia operativa y mejora continua.

Modelo práctico de riesgo

Nivel	Ejemplos	Controles sugeridos
Bajo	Resumen de documentos públicos; borradores no enviados.	Fuentes conocidas, aviso de límites, revisión por muestreo.
Medio	Consulta interna de CRM o análisis de datos empresariales.	Acceso por rol, logs, validación de salida y controles de exportación.
Alto	Cambiar registros, enviar mensajes externos, aprobar gastos o modificar producción.	Permisos restringidos, aprobación previa, límites, pruebas y rollback.
Crítico	Pagos relevantes, decisiones reguladas o acciones irreversibles.	Supervisión humana reforzada, segregación de funciones, doble control y auditoría independiente.

No todo requiere la misma fricción: el control debe ser proporcional al impacto, la reversibilidad y la exposición de datos.

9. Preguntas para discusión ejecutiva

1. ¿Dónde termina la responsabilidad del modelo y empieza la de la organización?
El modelo es un componente del sistema. La organización sigue siendo responsable de definir el propósito, seleccionar herramientas, controlar accesos, validar resultados y supervisar el proceso. La delegación técnica no elimina la responsabilidad de negocio.

2. ¿Es suficiente una política de uso responsable de IA?
No. La política necesita controles técnicos: autenticación, permisos por recurso, prevención de fuga, límites de ejecución, aprobación, monitorización y respuesta a incidentes. Sin mecanismos de cumplimiento, la política depende de la conducta individual.

3. ¿Qué debe cambiar al pasar de un chatbot a un agente?
El agente necesita controles de ejecución además de controles de contenido: identidad propia, alcance mínimo, lista de herramientas permitidas, validación de parámetros, separación de entornos, aprobación de acciones sensibles y trazabilidad de resultados.

Patrón de arquitectura recomendado

Capa	Responsabilidad
Plano de control	Identidad, políticas, permisos, cuotas, aprobaciones, secretos y kill switch.
Plano de ejecución	Herramientas, conectores, sandbox, validación de entradas/salidas y límites de acciones.
Plano de evidencia	Eventos correlacionados, métricas, logs protegidos, auditoría y respuesta a incidentes.

10. Autoevaluación de madurez

Marque cada control como implantado, parcial o ausente. Esta lista es una herramienta de diagnóstico interno, no una auditoría de certificación.

#	Dimensión	Control a verificar	Estado
1	Datos	Existe inventario de fuentes y propietarios.	■ Sí ■ Parcial ■ No
2	Datos	Los datos están clasificados por sensibilidad y finalidad.	■ Sí ■ Parcial ■ No
3	Datos	Se conoce el linaje y la fecha de actualización de fuentes relevantes.	■ Sí ■ Parcial ■ No
4	Datos	Se controlan calidad, retención y eliminación.	■ Sí ■ Parcial ■ No
5	Agentes y acceso	Cada agente usa identidad propia o identidad técnica controlada.	■ Sí ■ Parcial ■ No
6	Agentes y acceso	Los permisos siguen mínimo privilegio y caducidad.	■ Sí ■ Parcial ■ No
7	Agentes y acceso	Las herramientas disponibles están permitidas por caso de uso.	■ Sí ■ Parcial ■ No
8	Agentes y acceso	Las acciones sensibles requieren aprobación o control equivalente.	■ Sí ■ Parcial ■ No
9	Evidencia	Se registran fuente, contexto y versión del modelo cuando procede.	■ Sí ■ Parcial ■ No
10	Evidencia	Las llamadas a herramientas y sus resultados quedan registradas.	■ Sí ■ Parcial ■ No
11	Evidencia	Los logs tienen acceso restringido, retención definida y protección de secretos.	■ Sí ■ Parcial ■ No
12	Evidencia	Se puede reconstruir un incidente con identificadores correlacionados.	■ Sí ■ Parcial ■ No
13	Responsabilidad	Existe propietario de negocio y responsable técnico por sistema.	■ Sí ■ Parcial ■ No
14	Responsabilidad	Hay proceso de evaluación de riesgos antes de producción.	■ Sí ■ Parcial ■ No
15	Responsabilidad	Los usuarios conocen limitaciones, usos permitidos y vías de escalado.	■ Sí ■ Parcial ■ No

#	Dimensión	Control a verificar	Estado
16	Responsabilidad	Hay procedimiento de incidentes y recuperación.	■ Sí ■ Parcial ■ No
17	Escala	Se realizan pruebas de regresión y evaluaciones periódicas.	■ Sí ■ Parcial ■ No
18	Escala	Se monitorizan fallos, excepciones y cambios de comportamiento.	■ Sí ■ Parcial ■ No
19	Escala	Se revisan permisos y accesos periódicamente.	■ Sí ■ Parcial ■ No
20	Escala	Existe un proceso de retirada o desactivación segura.	■ Sí ■ Parcial ■ No

Lectura orientativa de resultados

Cuente los controles implantados, parciales y ausentes. Si hay ausencias en identidad, permisos, acciones sensibles o trazabilidad, priorícelas antes de ampliar el uso de agentes. Una puntuación agregada no sustituye el análisis de riesgos: un único control crítico ausente puede ser suficiente para bloquear un caso de uso.

Cierre: cinco preguntas para una revisión trimestral

¿Qué agentes están activos? · ¿Qué datos consultan? · ¿Qué acciones pueden ejecutar? · ¿Qué evidencias generan? · ¿Quién puede revocar su acceso o detenerlos?

Referencias de orientación: ISO/IEC 42001:2023; NIST AI Risk Management Framework 1.0 (2023); Reglamento (UE) 2024/1689 (AI Act); RGPD (Reglamento (UE) 2016/679); DAMA-DMBOK. Consulte las publicaciones oficiales para los requisitos y calendarios vigentes.